Design and apply context-aware access controls based on user identity, device posture, location, and application risk.

COLLEGE NAME: Shri Nehru Maha Vidyalaya College Of Arts And Science

TEAM ID: SWTID-2026-8039

TEAM LEADER: PREMA P

EMAIL ID: 23snmvbcaprema@gmail.com

TEAM MEMBER : CHANDRU BALAJI V

EMAIL ID: 23bcachandrubalajiv@gmail.com

TEAM MEMBER: JESI A

EMAIL ID: 23bcajesi@gmail.com

TEAM MEMBER: SYED HAMEED M

EMAIL ID: nn1572881@gmail.com

PROJECT TITLE

Design and apply context-aware access controls based on user identity

Overview of the project

In an era where the digital landscape is constantly evolving, organizations face an ever-increasing threat from cyberattacks. The need for swift and effective incident response has become paramount to safeguard sensitive data, protect digital assets, and maintain the trust of stakeholders. In response to this growing challenge, we present a visionary project: the development of an AI-driven incident response platform that empowers cybersecurity teams with the tools to automate and enhance incident triage and response tasks. The traditional network perimeter has all but dissolved in the modern digital landscape. With the mass adoption of cloud services, remote work, and personal mobile devices (BYOD), corporate resources are no longer confined to a single office building. This shift has rendered the conventional "castle-and-moat" security model—where anyone inside the network is trusted by default—obsolete and dangerously insufficient. Modern organizations now face the complex challenge of securing access to sensitive data from a diverse and ever-changing array of locations, devices, and user environments. To address this, security strategies must evolve from static, location-centric models to dynamic, identity-centric frameworks that assess the risk of every access request in real-time. This project focuses on the design and implementation of a context-aware access control system to solve this exact challenge. By moving beyond simple username and password verification, this system will evaluate a rich set of contextual signals before granting access to applications and data. These signals include the user's identity and role, the security posture of their device (e.g., is it patched, encrypted, and managed?), their geographic location, and the inherent risk level of the application they are attempting to use. By analyzing these factors in unison, the system can make a granular, real-time decision: grant full access, restrict access to certain features, require step-up authentication (like multi factor authentication), or block the request entirely. Ultimately, this project aims to build a security architecture that is both robust and frictionless. For example, a trusted employee accessing a low-risk application from a secured corporate laptop on the office network might have a seamless login experience. Conversely, that same employee attempting to access a critical financial system from an unpatched personal device in a foreign country would be met with additional security challenges or be completely blocked. This intelligent, adaptive approach not only significantly reduces the attack surface and protects

against compromised credentials but also enables a secure and productive work environment for a modern, mobile workforce.

ABSTRACT

The increasing adoption of cloud services, mobile computing, and hybrid work models has fundamentally broken the traditional network perimeter, rendering legacy access control models ineffective. Organizations now struggle to protect sensitive data from a growing attack surface, where threats can originate from compromised endpoints, unsafe locations, or malicious insiders. Static, binary decisions (allow or deny) are no longer sufficient to mitigate the sophisticated risks present in modern distributed environments. There is a critical need for a dynamic security framework that can evaluate the full context of every access request in real-time. This project presents the design and application of a context-aware access control system based on user identity, device posture, geolocation, and application risk. The objective is to develop a policy engine that ingests multiple contextual signals to calculate a real-time risk score for each access attempt. The methodology involves defining granular policies that map specific context combinations (e.g., "managed device" + "corporate network" + "low-risk app") to corresponding access decisions, such as granting full access, enforcing step-up authentication (MFA), limiting session functionality, or denying access entirely. The expected outcome is an adaptive security model that significantly reduces the organizational attack surface and mitigates the risk of credential compromise. By ensuring that access decisions are dynamically aligned with the perceived threat level of each request, the system enhances security without introducing unnecessary friction for low-risk, trusted users. This approach provides a robust framework for enabling secure and productive access to resources in an increasingly perimeter-less and dynamic digital world.

Use Case Scenarios

Scenario 1: Finance Department Access to ERP System A senior accountant in the finance department needs to access the corporate Enterprise Resource Planning (ERP) system to process monthly payroll. The user connects from a remote location using their company-managed laptop. Upon launching the ZPA Client Connector, they authenticate via Azure Active Directory with multi-factor authentication (MFA).

Output:

- User authenticated and authorized based on identity and group membership
- Direct micro-tunnel established specifically to the ERP application

• All other internal applications and network segments remain invisible and inaccessible.

Scenario 2: Contractor Access to Specific Project Repository An external software consultant is hired for a three-month project and requires access only to a specific Git repository hosted on an internal server. The contractor is onboarded as a guest user in the identity provider and assigned to the "Project_X_Contractors" group. When the contractor connects using the ZPA client, the system verifies their identity and checks the device for basic security compliance (OS patch level, firewall enabled). ZPA enforces a policy that grants access exclusively to the Git repository application (port 22/SSH or port 443/HTTPS) during business hours (9 AM to 5 PM).

Output:

• Time-bound and role-specific access enforced

• Contractor restricted to a single application (Git repository)

• Lateral movement to adjacent systems completely blocked

Scenario 3: Executive Access to Sensitive Financial Documents A company VP needs to access a folder containing confidential M&A documents stored in a corporate SharePoint site. The user connects from a hotel business center while traveling internationally, using their companymanaged tablet. Upon launching the ZPA Client Connector, they authenticate via Azure Active Directory with MFA.

Output:

• User authenticated with MFA and device compliant, but flagged for unusual location

• Read-only access granted with download/print restrictions enforced

• Security team alerted to potential credential misuse or espionage attempt

Scenario 4: Remote Support Technician Access to Internal Tools An IT support technician needs to access the corporate ServiceNow instance and a remote desktop tool to assist an employee. The technician connects from their home office using a company-managed desktop. Upon launching the ZPA Client Connector, they authenticate via Azure Active Directory with MFA. ZPA evaluates the user's identity, group membership (IT_Support), device posture (fully compliant), and connection type (home office, which is whitelisted for IT staff).

Output:

• User authenticated and fully authorized based on trusted context .

• Direct micro-tunnels established to ServiceNow and the remote desktop jump host .

• Least-privilege access maintained; unrelated internal systems remain invisible.

Scenario 5: High-Risk Application Access from a Low-Trust Location A marketing coordinator needs to access the corporate Salesforce instance to update a campaign. The user connects from a coffee shop using their company-managed smartphone. Upon launching the ZPA Client Connector, they authenticate via Azure Active Directory with MFA. ZPA evaluates the user's identity, group membership (Marketing_Salesforce_Users), device posture (managed and compliant), but flags the public Wi-Fi network as a high-risk connection.

Output:

- User authenticated and device compliant, but network location deemed high-risk
- Access granted via browser isolation to prevent data leakage on public Wi-Fi
- Session is rendered in a secure container with copy/paste and download controls enforced.

Stage – 1

Title: OWASP TOP 10

Overview

The **OWASP Top 10** is a globally recognized list of the most critical security risks to web applications, maintained by the **Open Web Application Security Project (OWASP)**, aimed at helping developers, security teams, and organizations prioritize protections. It identifies the most common vulnerabilities, starting with **Broken Access Control**, where improper enforcement of user permissions allows unauthorized actions, and **Cryptographic Failures**, which involve weak encryption or mishandling of sensitive data. **Injection flaws**, such as SQL or command injection, occur when untrusted input is sent to interpreters, while **Insecure Design** arises from missing security considerations in the development process. **Security Misconfiguration** refers to improper setup of systems or software, and **Vulnerable and Outdated Components** highlight the dangers of using libraries or frameworks with known security issues. **Identification and Authentication Failures** include weak passwords, session flaws, or missing multi-factor authentication, and **Software and Data Integrity Failures** involve unverified updates or unsafe deserialization. **Security Logging and Monitoring Failures** can prevent timely detection of breaches, and **Server-Side Request Forgery (SSRF)** allows attackers to manipulate servers into accessing unintended internal resources. Collectively, the OWASP Top 10 provides a practical baseline for **secure coding, risk assessment, proactive monitoring, and mitigation strategies**, helping organizations reduce the likelihood and impact of web application attacks while fostering a culture of security-aware development.

List of vulnerability

S.No	Vulnerability Name	CWE/CVE No
1	Absolute Path Traversal	CWE 36
2	Sensitive Cookie in HTTPS Session Without 'Secure' Attribute	CWE-614
3	Dependency on Vulnerable Third-Party Component	CWE-1395
4	Missing Cryptographic Step	CWE-325
5	Improper Input Validation	CWE-20
6	Trust Boundary Violation	CWE-501
7	Weak Password Requirements	CWE-521
8	Missing Support for Integrity Check	CWE-353
9	Information Loss or Omission	CWE-221
10	Unchecked Return Value	CWE-252

Report:

1) Vulnerability Name: Absolute Path Traversal

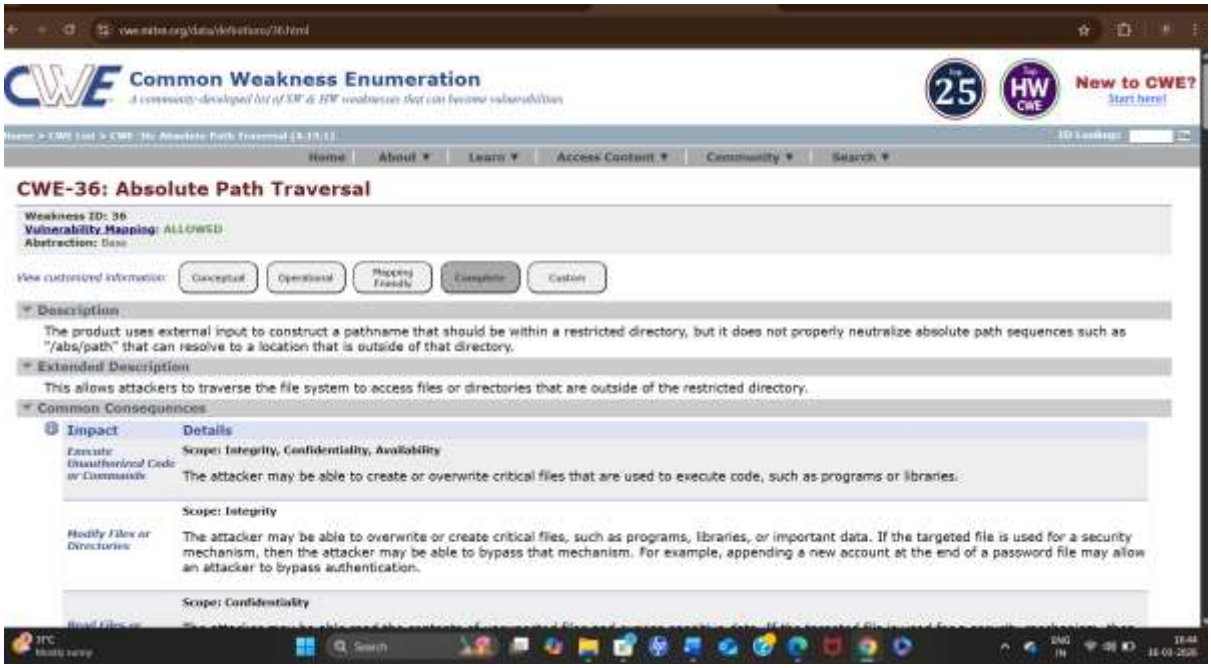
CWE NO: CWE 36

OWASP Category: A01:2025 Broken Access Control

Description: Absolute Path Traversal happens when a web application accepts user-supplied input as a file path and directly uses it to access files on the system. If the application does not properly validate or sanitize this input, an attacker can provide a full absolute path (starting from the root directory) to read or sometimes modify sensitive files on the server.Instead of being limited to the intended directory, the attacker can access files anywhere on the server's file system.

Business Impact: Absolute Path Traversal may allow attackers to access sensitive files such as configuration files, credentials, or system data. This can lead to data breaches, unauthorized system access, and exposure of confidential information. The

vulnerability may cause service disruption, reputational damage, financial loss, and potential legal or regulatory consequences for the organization.



2)Vulnerability Name: Sensitive Cookie in HTTPS Session Without 'Secure' Attribute

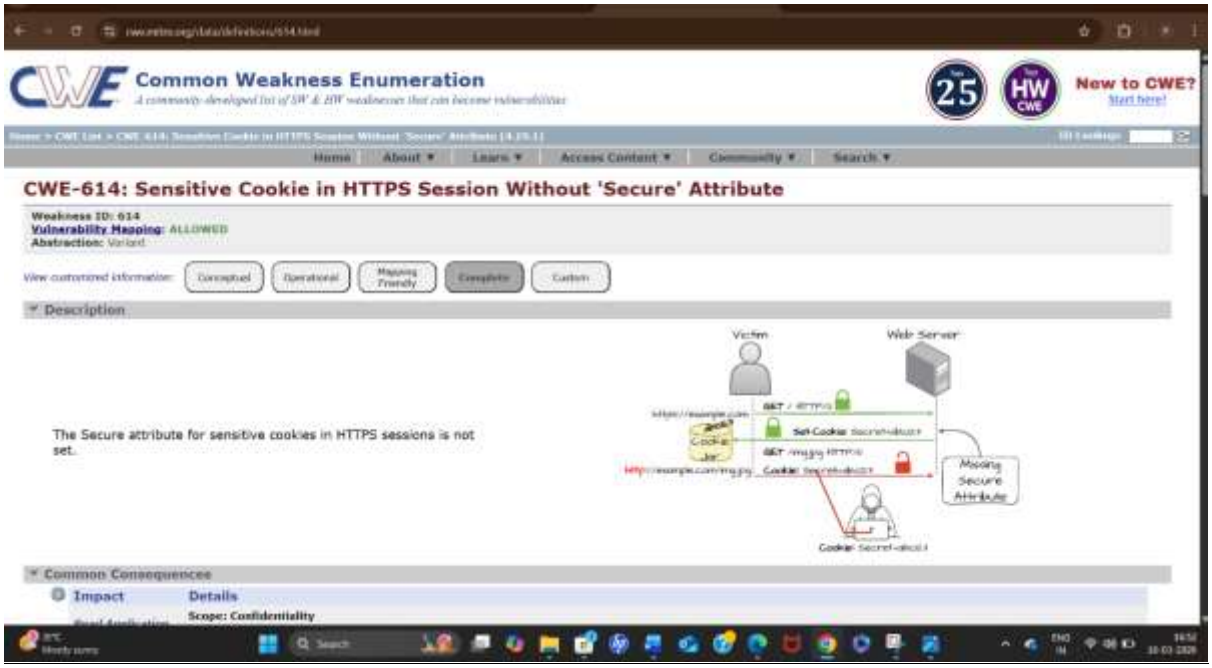
CWE NO: CWE 614

OWASP Category: A02:2025 Security Misconfiguration

Description: The Sensitive Cookie in HTTPS Session Without 'Secure' Attribute vulnerability occurs when a web application sets cookies containing sensitive information (such as session IDs or authentication tokens) without enabling the Secure attribute.The Secure attribute ensures that cookies are transmitted only over HTTPS connections. When this attribute is missing, the browser may send the cookie over an unencrypted HTTP connection, even if the user initially accessed the application through HTTPS.This behavior exposes sensitive session cookies to potential interception through man-in-the-middle (MITM) attacks, network sniffing, or insecure network environments. If an attacker captures the session cookie, they may use it to hijack the user's session and gain unauthorized access to the application without needing valid credentials.

Business Impact: Missing the Secure attribute on sensitive cookies may allow attackers to intercept session cookies over insecure connections. This can lead to session hijacking, unauthorized account access, and exposure of sensitive user data.

Such incidents may result in data breaches, financial losses, reputational damage, and potential legal or regulatory compliance issues for the organization.



3)Vulnerability Name: Dependency on Vulnerable Third-Party Component

CWE NO: CWE 1395

OWASP Category: A03:2025 Software Supply Chain Failures

Description: Dependency on Vulnerable Third-Party Component is a security vulnerability that occurs when an application uses external libraries, frameworks, plugins, or software components that contain known security flaws.Modern applications commonly rely on third-party components to speed up development and provide additional functionality. However, if these components are outdated or contain known vulnerabilities, attackers may exploit those weaknesses to compromise the application.These vulnerabilities are often publicly documented in security databases such as the Common Vulnerabilities and Exposures (CVE) and monitored through the National Vulnerability Database. If developers fail to regularly update or patch these components, the application inherits the security risks associated with them.

Business Impact: Using vulnerable third-party components may expose the application to known security flaws that attackers can exploit. This can lead to unauthorized access, data breaches, system compromise, or service disruption. Such incidents may result in financial losses, operational downtime, reputational damage, and potential legal or regulatory compliance issues for the organization.

4)Vulnerability Name: Missing Cryptographic Step

CWE NO: CWE-325

OWASP Category: A04:2025 Cryptographic Failures

Description: Missing Cryptographic Step is a security vulnerability that occurs when an application fails to apply necessary cryptographic protections, such as encryption, hashing, or digital signing, during data processing or transmission.Cryptographic mechanisms are essential for protecting sensitive information such as passwords, session tokens, and confidential data. When a required cryptographic step is omitted, the data may be stored or transmitted in plain text or with weak protection.This weakness can expose sensitive information to attackers through interception, unauthorized access, or data manipulation. As a result, attackers may be able to read, modify, or misuse sensitive data

Business Impact: Missing cryptographic protection may expose sensitive data such as passwords, personal information, or financial details in plain text. Attackers could intercept or manipulate this data, leading to unauthorized access and data breaches. This may cause financial losses, regulatory penalties, operational disruption, and reputational damage, ultimately reducing customer trust in the organization.

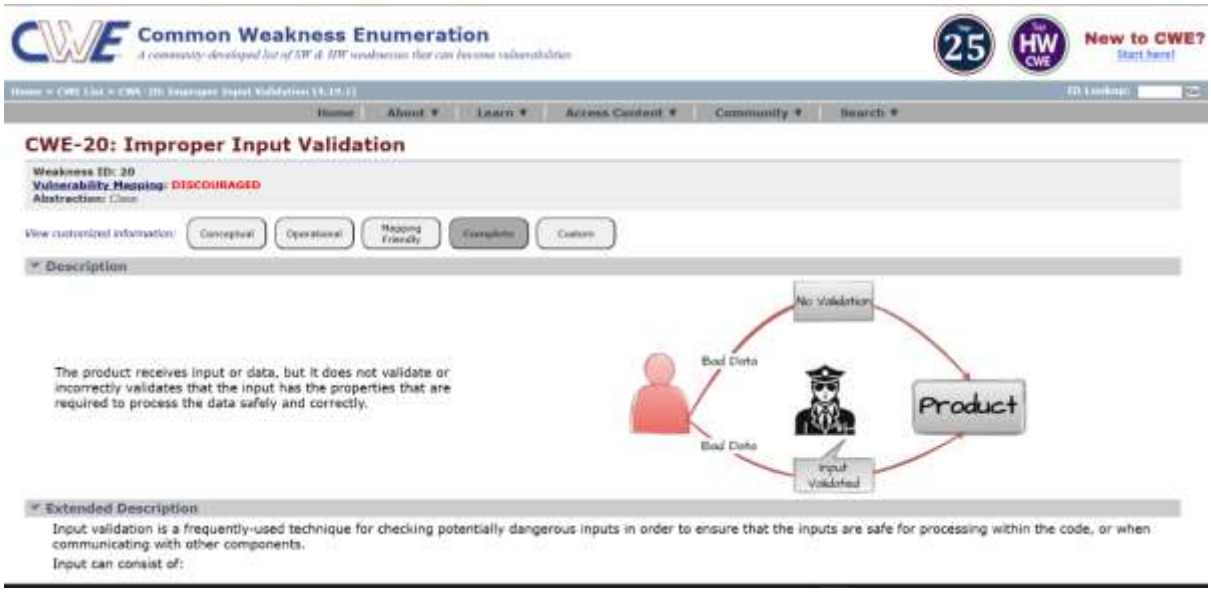
5)Vulnerability Name: Improper Input Validation

CWE NO: CWE-20

OWASP Category: A05:2025 Injection

Description: Improper Input Validation is a security vulnerability that occurs when an application fails to properly validate or sanitize user-supplied input before processing it. Applications often accept input from users through forms, URLs, cookies, or APIs, and if this input is not properly checked, attackers may submit malicious data.Without proper validation, the application may process unexpected or harmful input, which can lead to various attacks such as injection attacks, unauthorized data access, or manipulation of application logic.This vulnerability can affect multiple parts of an application, including databases, file systems, and system commands. Attackers may exploit it to bypass security controls, access restricted resources, or disrupt normal application functionality.

Business Impact: Improper Input Validation can allow attackers to inject malicious data, bypass security controls, or manipulate application behavior. This may lead to data breaches, unauthorized access, service disruption, or financial fraud. The organization risks regulatory penalties, operational downtime, reputational damage, and loss of customer trust due to compromised application security.



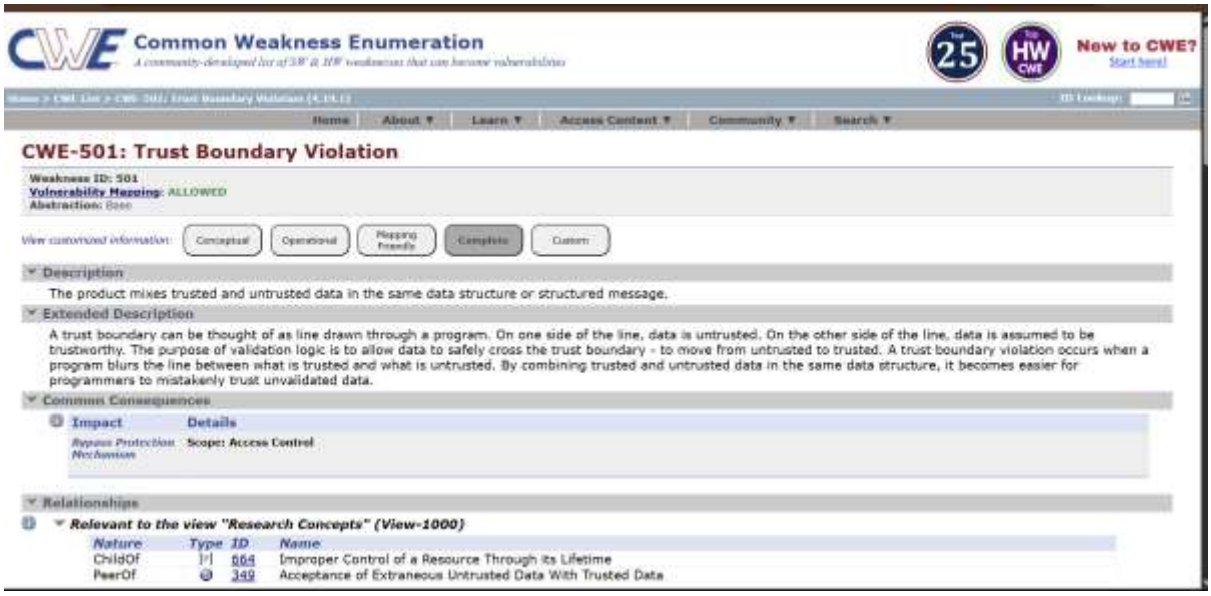
6)**Vulnerability Name:** Trust Boundary Violation

CWE NO: CWE-501

OWASP Category: A06:2025 Insecure Design

Description: A Trust Boundary Violation is a type of security vulnerability that occurs when data or control flows cross a trust boundary in a system without proper validation or verification. A trust boundary is the point at which different levels of trust exist—for example, between user input and server-side logic, between different subsystems, or between a client and a server. Violating this boundary can allow attackers to manipulate data, bypass security controls, or execute unauthorized actions.

Business Impact: A Trust Boundary Violation occurs when untrusted data crosses a system's trust boundary without proper validation or verification. From a business perspective, it can have serious consequences. Sensitive customer or corporate data may be exposed, leading to data breaches and regulatory fines. Attackers can manipulate transactions or bypass security controls, causing financial loss. Exploited vulnerabilities may disrupt operations, resulting in downtime and reduced productivity. Publicized incidents damage brand reputation and customer trust. Additionally, organizations face compliance risks and potential legal action. Overall, trust boundary violations pose a high strategic, operational, and financial risk to any business.



7)**Vulnerability Name:** Weak Password Requirements

CWE NO: CWE-521

OWASP Category : A07:2025 Authentication Failures

Description: A Weak Password Requirements vulnerability arises when a system allows users to create easily guessable or simple passwords. This includes short passwords, common words, predictable patterns, or lack of character diversity, making accounts susceptible to brute-force, dictionary, or credential-stuffing attacks. Exploiting this vulnerability can lead to unauthorized access, data theft, account compromise, and potential lateral movement within an organization's systems. Examples include passwords like "12345" or "password" and no enforcement of complexity rules or reuse restrictions. Prevention involves enforcing strong password policies, requiring a mix of letters, numbers, and symbols, implementing multi-factor authentication, and encouraging regular password updates.

Business Impact: A Weak Password Requirements vulnerability poses significant business risks. Weak passwords make it easier for attackers to compromise user accounts, leading to unauthorized access to sensitive corporate or customer data. This can result in data breaches, regulatory fines, and legal penalties. Account compromises may allow fraud, financial loss, or manipulation of critical systems, disrupting operations and causing downtime. Public disclosure of such incidents harms brand reputation and erodes customer trust. Additionally, organizations face compliance risks if password policies fail to meet standards like GDPR, HIPAA, or PCI-DSS. Overall, weak password enforcement threatens financial, operational, and strategic business stability.

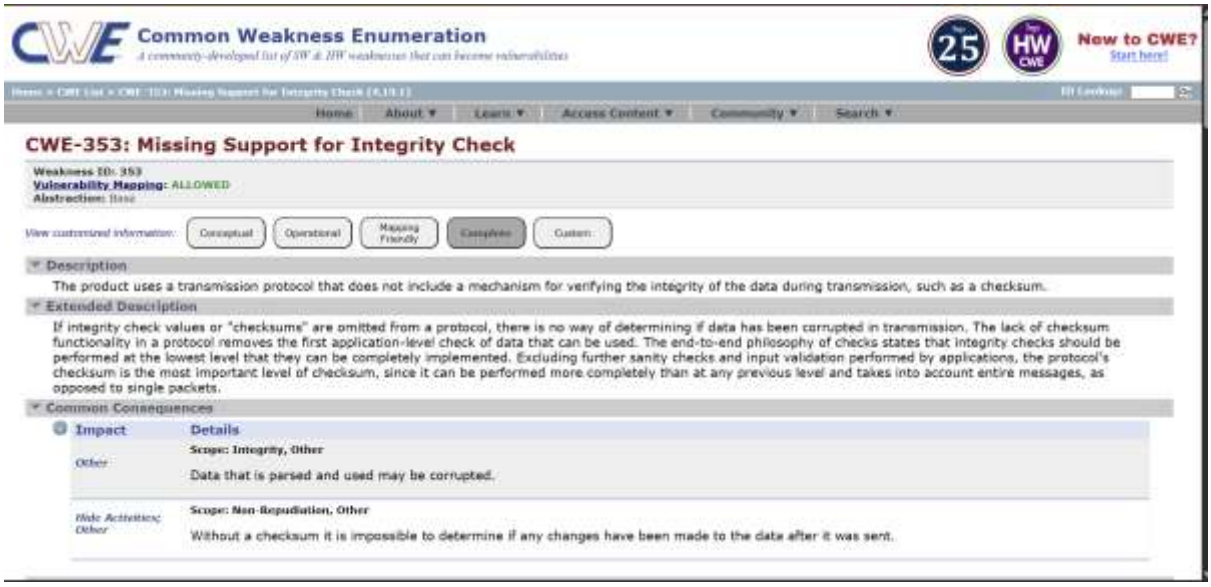
8) Vulnerability Name: Missing Support for Integrity Check

CWE NO: CWE-353

OWASP Category : A08:2025 Software or Data Integrity Failures

Description: A Missing Support for Integrity Check vulnerability occurs when a system fails to verify that data has not been altered, corrupted, or tampered with during storage or transmission. Integrity checks ensure that information remains accurate and trustworthy, typically using mechanisms like checksums, hashes, or digital signatures.

Business Impact: A Missing Support for Integrity Check vulnerability can have serious business consequences. Without integrity verification, data can be altered, corrupted, or tampered with without detection, leading to unauthorized changes in critical information. This can result in financial losses, fraud, or operational errors idecisions are made based on compromised data. It may also damage **customer trust** if sensitive information is affected and lead to **regulatory or compliance violations** in industries with strict data protection standards. Additionally, attackers could inject malicious code or manipulate software updates, causing **system downtime, reputational damage, and strategic risks** for the organization.



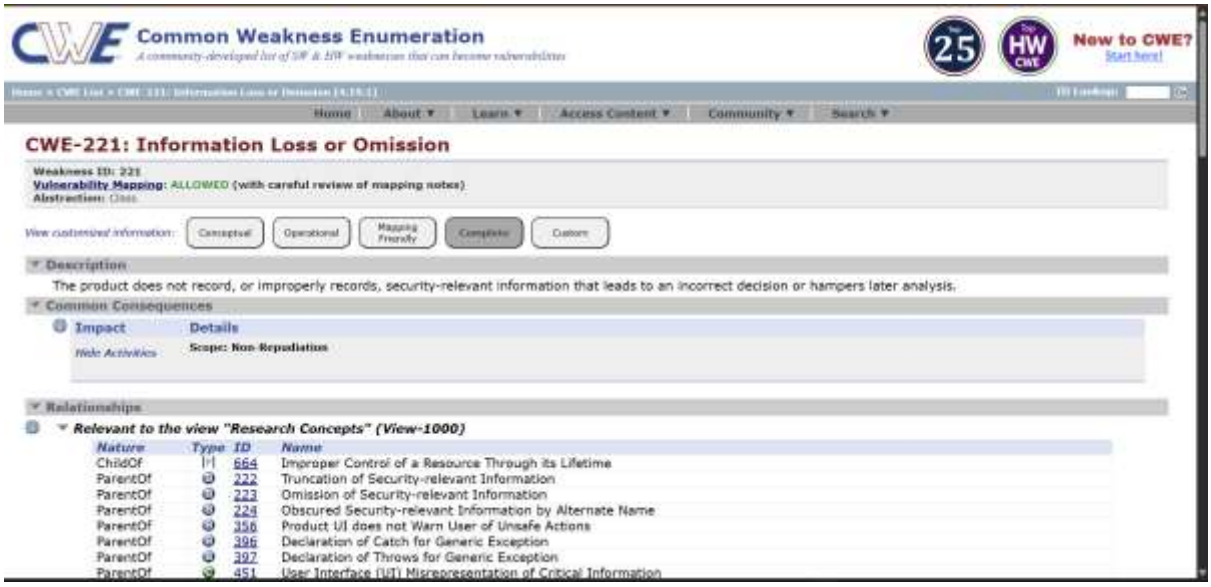
9)Vulnerability Name: Information Loss or Omission

CWE NO: CWE-221

OWASP Category: A09:2025 Security Logging & Alerting Failures

Description: A Information Loss or Omission vulnerability occurs when a system fails to capture, store, transmit, or present critical information accurately. This can result from software bugs, improper error handling, incomplete logging, or flawed data processing. Such gaps mean that important data may be missing, corrupted, or never recorded, potentially causing incorrect decisions or system failures. Examples include financial transactions not being recorded, logs failing to capture security events, or data being truncated during transmission. Prevention involves robust error handling, regular data validation, secure storage, and auditing mechanisms. This vulnerability undermines **data reliability, operational integrity, and business trust**.

Business Impact: A Information Loss or Omission vulnerability can have serious business consequences. Missing or incomplete data can lead to incorrect decisions, operational errors, and financial losses. Critical transactions or records may be lost, resulting in regulatory non-compliance and potential legal penalties. Failure to capture security events or audit logs can weaken security monitoring, increasing the risk of undetected breaches. Additionally, customer trust may be eroded if important information is lost or mishandled, harming the organization's reputation. Overall, information loss or omission undermines data reliability, disrupts operations, exposes the business to compliance risks, and can create long-term strategic and financial impacts.



10)Vulnerability Name: Unchecked Return Value

CWE NO :CWE-252

OWASP Category: A10:2025 Mishandling of Exceptional Conditions

Description: A Unchecked Return Value vulnerability occurs when a program calls a function or method but fails to verify or handle its return value. Many functions return status codes, error messages, or results that indicate success, failure, or unexpected conditions. Ignoring these return values can lead to unhandled errors, incorrect program behavior, or security weaknesses.

Business Impact: A Unchecked Return Value vulnerability can have significant business consequences. Ignoring function or method return values may lead to program errors, crashes, or data corruption, disrupting business operations. It can allow attackers to exploit unhandled errors, potentially resulting in unauthorized access, privilege escalation, or security breaches. Missed errors in critical processes may cause financial losses, regulatory non-compliance, or operational delays. Additionally, repeated failures or undetected issues can damage customer trust and brand reputation. Overall, failing to handle return values undermines system reliability, exposes sensitive data, increases operational risk, and creates both financial and strategic impacts for the organization.

Common Weakness Enumeration

A community-developed list of SW & HW weaknesses that can become vulnerabilities

New to CWE?
Start here!

Home > CWE List > CWE- 252: Unchecked Return Value (4.15.1)

ID Lookup:

Home | About ▾ | Learn ▾ | Access Content ▾ | Community ▾ | Search ▾

CWE-252: Unchecked Return Value

Weakness ID: 252
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product does not check the return value from a method or function, which can prevent it from detecting unexpected states and conditions.

Extended Description

Two common programmer assumptions are "this function call can never fail" and "it doesn't matter if this function call fails". If an attacker can force the function to fail or otherwise return a value that is not expected, then the subsequent program logic could lead to a vulnerability, because the product is not in a state that the programmer assumes. For example, if the program calls a function to drop privileges but does not check the return code to ensure that privileges were successfully dropped, then the program will continue to operate with the higher privileges.

Common Consequences

Impact	Details
Unexpected State; DoS: Crash, Exit, or Restart	**Scope: Availability, Integrity** An unexpected return value could place the system in a state that could lead to a crash or other unintended behaviors.

Potential Mitigations

Phase(s)	Mitigation
Implementation	Check the results of all functions that return a value and verify that the value is expected.

Stage 2:

Title: Nessus scan

Overview

Nessus is a widely used vulnerability assessment tool developed by Tenable. It is designed to help organizations identify security weaknesses in their IT infrastructure, including servers, networks, databases, and applications. Nessus is commonly used by security professionals, system administrators, and ethical hackers to proactively detect vulnerabilities before attackers can exploit them.

At its core, Nessus performs automated scans of systems and compares findings against a continuously updated database of known vulnerabilities, misconfigurations, and compliance issues. It supports thousands of plugins, which are regularly updated to detect new threats such as malware, unpatched software, weak passwords, and open ports. Nessus can also identify issues related to regulatory compliance standards like PCI-DSS, HIPAA, and CIS benchmarks.

One of the key strengths of Nessus is its ease of use. It provides a user-friendly web interface where users can configure scans, view reports, and prioritize risks based on severity levels. The tool categorizes vulnerabilities into levels such as Critical, High, Medium, and Low, helping organizations focus on the most urgent threats first. It also offers detailed remediation guidance, enabling faster resolution of security issues.

Nessus supports multiple scan types, including credentialed scans (which provide deeper system insights) and non-credentialed scans (which simulate external attacker perspectives). It can be deployed on various platforms and integrates with other security tools for enhanced threat management.

In summary, Nessus is a powerful and reliable vulnerability scanning solution that plays a crucial role in modern cybersecurity strategies. By continuously identifying and assessing risks, it helps organizations strengthen their security posture and reduce the likelihood of cyberattacks.

S.NO	Vulnerability Name	Severity	Plugins
1	Nessus SYN Scanner	INFO	11219
2	Service Detection	INFO	29642
3	J Query Detection	INFO	106658
4	Additional DNS Hostname	INFO	46180
5	Device type	INFO	54615
6	SSL Version 2 and 3 Protocol Detection	CRITICAL	2007
7	Apache Tomcat SEoL (7.0.x)	CRITICAL	171351
8	SSL DROWN Attack Vulnerability (Decrypting RSA with Obsolete and Weakened eNcryption	MEDIUM	89058
9	SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)	LOW	83875
10	SSL Medium Strength Cipher Suites Supported (SWEET32	HIGH	42873

REPORT:

1)Vulnerability: Nessus SYN Scanner

Severity: INFO

Plugin: 11219

Description: The Nessus SYN Scanner plugin performs a TCP SYN scan to identify open TCP ports on a target host.
It sends a SYN packet to a port and analyzes the response:

- SYN/ACK → Port is open
- RST → Port is closed

- No response / filtered → Port may be filtered by a firewall

This method is commonly called a “half-open scan” because the TCP connection is not fully established. Nessus uses it to quickly detect running services and exposed ports on the target system.

Solution: Since this plugin is informational, it mainly reports network discovery results, but reviewing exposed services is still important for security.

Bussiness Impact: This is not a vulnerability by itself, but it indicates that:

- The scanner successfully identified open ports and services.
- Unnecessary or exposed services may increase the attack surface.
- Attackers could use similar scanning techniques to discover services and potential entry points.
- If critical services are exposed (e.g., SSH, FTP, databases), they could be targeted for exploitation

2)Vulnerability: Service Detection

Severity: INFO

Plugin: 29642

Description: This plugin identifies services running on open ports of the target system. Nessus analyzes responses from the ports to determine the type of service and sometimes the version (for example: HTTP, SSH, FTP, SMTP).

Solution: □ Review the detected services and ensure they are necessary.

□ Disable or close unused services and ports.

□ Update and patch services regularly.

□ Use firewalls or access controls to restrict service access to trusted users or networks.

Bussiness Impact: This is not a vulnerability, but it shows which services are exposed on the network. Attackers could use this information to identify potential targets for attacks if the services are outdated or misconfigured.

3)Vulnerability: J Query Detection

Severity: INFO

Plugin: 106658

Description: This plugin detects the presence of the jQuery JavaScript library on the web application. It identifies the version of jQuery being used by analyzing the website's source code

Solution: □ Check the detected jQuery version.

□ If it is outdated, upgrade to the latest stable version of jQuery.

□ Regularly update third-party libraries used in the application.

□ Monitor security advisories for new vulnerabilities affecting jQuery.

Bussiness Impact: This is informational, but if the detected jQuery version is outdated, it may contain known security vulnerabilities. Attackers could exploit these vulnerabilities to perform attacks such as Cross-Site Scripting (XSS) or other client-side attacks

4)Vulnerability: Additional DNS Hostname

Severity: INFO

Plugin: 46180

Description: This plugin reports additional DNS hostnames that resolve to the same IP address as the scanned target. It means the server may be hosting multiple domains or subdomains on the same system.

Solution: Review the listed DNS hostnames to ensure they are expected and authorized.

Remove unused or unnecessary DNS records.

Apply proper security controls and updates to all hosted domains and services**.**

Bussiness Impact: This is not a vulnerability, but it reveals other hostnames associated with the server. Attackers could use this information to discover additional websites or services hosted on the same server and target them for attacks

5)Vulnerability: Device type

Severity: INFO

Plugin: 54615

Description: The Device Type plugin identifies the type of device running at the scanned IP address. Nessus analyzes network responses and determines whether the device is a server, workstation, router, firewall, printer, or other network device**.**

Solution: verify that the detected device type is correct and expected.

Ensure the device is properly secured and updated.

Apply appropriate security configurations based on the device type (e.g., firewall rules, access controls, firmware updates).

Bussiness Impact: This is informational only and does not indicate a vulnerability. However, knowing the device type helps security teams understand the network environment and identify which devices may require security controls or monitoring

6)Vulnerability: SSL Version 2 and 3 Protocol Detection

Severity: CRITICAL

Plugin:2007

Description: The scan detected that the server supports SSLv2 and/or SSLv3 protocols. These are outdated and insecure encryption protocols that have known vulnerabilities (such as POODLE attack). Attackers can exploit these weaknesses to decrypt sensitive data or perform man-in-the-middle attacks.

Solution: □ Disable SSLv2 and SSLv3 protocols on the server.

□ Enable only secure protocols such as TLS 1.2 and TLS 1.3.

□ Update the web server or SSL/TLS configuration.

□ Use strong cipher suites and follow modern security standards.

Bussiness Impact: □ Sensitive information (login credentials, session cookies, or personal data) could be intercepted or decrypted.

□ Attackers may perform Man-in-the-Middle (MITM) attacks.

□ This can lead to data breaches, compliance violations, and loss of customer trust.

7)Vulnerability: Apache Tomcat SEoL (7.0.x)

Severity: CRITICAL

Plugin: 171351

Description: The scan detected that the server is running Apache Tomcat version 7.0.x, which has reached End of Life (EoL). This means the vendor no longer provides security updates or patches for this version. As a result, any newly discovered vulnerabilities will not be fixed, leaving the system exposed.

Solution: Upgrade Apache Tomcat to a supported version such as Tomcat 9.x, 10.x, or later.

- Apply the latest security patches and updates.
- Regularly monitor vendor advisories for new vulnerabilities and updates.

- After upgrading, rescan the system to verify the vulnerability is resolved.

Bussiness Impact: The server may contain known or future unpatched vulnerabilities.

 Attackers could exploit these weaknesses to gain unauthorized access, execute remote code, or compromise the web application.

 This may lead to data breaches, system compromise, service disruption, and compliance issues.

8)Vulnerability: SSL DROWN Attack Vulnerability (Decrypting RSA with Obsolete and Weakened eNcryption

Severity: MEDIUM

Plugin: 89058

Description: The scan detected that the server is vulnerable to the DROWN attack, which occurs when a server supports the obsolete SSLv2 protocol or shares the same private key with another server that supports SSLv2. Attackers can exploit this weakness to decrypt secure HTTPS connections, even if modern TLS protocols are used.

Solution: Disable SSLv2 completely on all servers.

 Ensure the server only supports secure protocols such as TLS 1.2 and TLS 1.3.

 Update and patch the web server and SSL/TLS libraries (e.g., OpenSSL).

 Avoid reusing the same SSL private key on servers that support weak protocols.

 After applying fixes, run another vulnerability scan to confirm the issue is resolve

Bussiness Impact: Attackers may decrypt sensitive encrypted traffic such as login credentials or personal data.

 This can lead to Man-in-the-Middle (MITM) attacks.

 It may result in data breaches, loss of confidentiality, and compliance violations

9)Vulnerability: SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)

Severity: LOW

Plugin: 83875

Description: The scan detected that the server supports weak Diffie-Hellman (DH) key exchange parameters with a modulus size of 1024 bits or less. This vulnerability is

known as the Logjam attack. Attackers may exploit weak DH parameters to downgrade the connection and decrypt secure communications**.**

Solution: □ Configure the server to use strong Diffie-Hellman parameters (2048 bits or higher).

□ Disable weak cipher suites that use small DH key sizes.

□ Enable modern TLS protocols such as TLS 1.2 or TLS 1.3.

□ Update the web server and cryptographic libraries (e.g., OpenSSL) to the latest versions.

□ After applying changes, restart the server and perform a new vulnerability scan to confirm the issue is resolved

- **Bussiness Impact**: Attackers may intercept and decrypt encrypted SSL/TLS traffic.
- Sensitive information such as login credentials, session cookies, and confidential data could be exposed.
- This can lead to Man-in-the-Middle (MITM) attacks, data breaches, and loss of data confidentiality.

10)Vulnerability: SSL Medium Strength Cipher Suites Supported (SWEET32

Severity: HIGH

Plugin: 42873

Description: The scan detected that the server supports medium-strength SSL/TLS cipher suites, specifically 64-bit block ciphers such as 3DES. These ciphers are vulnerable to the SWEET32 attack, which allows attackers to exploit the small block size and potentially recover sensitive information from encrypted sessions

Solution: □ Disable weak and medium-strength cipher suites, especially 3DES.

□ Configure the server to allow only strong cipher suites (e.g., AES-GCM).

□ Enable modern TLS protocols such as TLS 1.2 and TLS 1.3.

□ Update the web server and SSL/TLS libraries to the latest versions.

□ Re-run the vulnerability scan after applying the changes to verify the fix.

Stage 3:

Title: Design and apply context-aware access controls based on user identity, device posture, location, and application risk.

Overview

In response to the evolving threat landscape and the dissolution of the traditional network perimeter, modern enterprises are rapidly shifting away from legacy VPN-centric remote access models. These conventional approaches often grant excessive network-level access, creating a significant attack surface and increasing the risk of lateral threat movement. To address these challenges, this project centers on the implementation of a Zero Trust security architecture, fundamentally operating on the principle of "never trust, always verify." By moving beyond location-based access, we aim to establish a security posture where trust is no longer implicit, and access is determined by granular context rather than network connectivity. The core of this initiative involves the deployment of Zscaler Private Access (ZPA), a cloud-delivered Zero Trust Access solution designed to create identity-aware, application-specific connectivity. Unlike traditional VPNs that place users on the internal network, ZPA leverages a "service-initiated" model to establish direct, one-to-one connections between authorized users and specific applications, completely hiding the corporate network and IP address space from the internet. This ensures that users connect exclusively to the applications they are permitted to access, based on continuous identity verification and context, rendering the applications invisible to unauthorized users and preventing common attack vectors such as port scanning and distributed denial-of-service (DDoS) attacks. Ultimately, this project will enforce a least-privilege access model, ensuring users and devices are granted the minimum required access necessary to perform their functions. By decoupling application access from network access, we will eliminate the risk of lateral movement across the network, as users have no visibility or connectivity to other hosts. This strategic move not only significantly enhances security by reducing the attack surface but also simplifies the user experience and reduces operational overhead associated with legacy remote access infrastructure, positioning the organization at the forefront of secure and efficient access management.

Identity

Modern security frameworks emphasize identity-driven and context-aware access control, which goes beyond traditional role-based permissions. Instead of granting access solely based on a user's role or credentials, systems evaluate multiple factors to determine whether a user should be allowed to access specific resources. User identity is the primary anchor, verifying who is requesting access. Device posture examines the security state of the device, such as whether it has up-to-date patches, antivirus protection, or is managed by the organization. Location provides contextual insight, restricting or flagging access from unusual or high-risk geographies, public networks, or untrusted environments. Application and transaction risk further fine-tunes access decisions by considering the sensitivity of the requested operation, historical user behavior, or anomalous patterns.

Device Posture

Device posture refers to the security state and compliance of a device requesting access to a system or application. When implementing context-aware access controls, evaluating device posture ensures that only devices meeting organizational security requirements are granted access. This includes checking whether the device is managed or unmanaged, whether it has up-to-date operating system patches, whether antivirus or endpoint protection is active, if disk encryption is enabled, and whether it is free from known malware or vulnerabilities.

By integrating device posture into access control decisions, organizations can reduce the risk of compromised devices accessing sensitive resources. For example, a corporate system may allow access only from company-managed laptops with current patches and security agents installed, while restricting or requiring additional verification for personal or out-of-date devices. Device posture, combined with user identity, location, and application risk, enables dynamic, context-aware security policies that adapt in real time to changing conditions, ensuring both security and usability.

Application Risk

Application risk refers to the level of potential threat or sensitivity associated with a specific application, resource, or operation when a user attempts to access it. In context-aware access control, assessing application risk allows security systems to make dynamic access decisions based not just on who the user is or what device they're using, but also on how critical or sensitive the target application or action is. High-risk applications—such as financial systems, HR databases, or administrative consoles—may require stricter verification, multi-factor authentication, or access restrictions based on other contextual factors. Conversely, low-risk applications, like general information portals, might allow more flexible access.

Application risk assessment considers factors such as data sensitivity, regulatory requirements, potential impact of a breach, and recent threat intelligence. By incorporating application risk into access decisions alongside user identity, device posture, and location, organizations can implement adaptive, intelligent security policies that protect critical resources while minimizing friction for legitimate users. This ensures that high-risk actions or sensitive applications receive stronger protection and reduces the likelihood of data breaches or unauthorized access.

Context Aware Access

Context-aware access is a security approach that dynamically determines whether a user should be granted access to a system or resource based on multiple contextual factors rather than just static credentials. Unlike traditional access control models that rely solely on username, password, or predefined roles, context-aware access evaluates real-time information about the user, their device, location, and the risk associated with the requested application or action.

Key components include:

- User identity: Confirms who is requesting access and ensures their authentication aligns with their role and privileges.
- Device posture: Checks the security state of the device, including patch levels, endpoint protection, and compliance with organizational policies.
- Location: Assesses whether the access request originates from trusted or unusual geographic locations or networks.
- Application risk: Evaluates the sensitivity or potential impact of the application or action being accessed.

By combining these factors, context-aware access enables adaptive and intelligent access decisions, such as requiring multi-factor authentication, limiting high-risk actions, or denying access from non-compliant devices. This approach strengthens security, reduces the risk of breaches, and maintains usability by providing flexible access tailored to the situation.

Conclusion:

Stage 1: The **OWASP Top 10** serves as an essential benchmark for understanding and addressing the most critical web application security risks. By identifying vulnerabilities such as broken access control, injection flaws, cryptographic weaknesses, and insecure design, it provides organizations and developers with a prioritized roadmap for securing applications. The list emphasizes that modern web security is **not just about fixing individual bugs**, but about adopting a **holistic approach** that integrates secure coding practices, threat modeling, continuous monitoring, and proactive risk management throughout the software development lifecycle.

Implementing the guidance from the OWASP Top 10 reduces the likelihood of data breaches, unauthorized access, and other security incidents, while also helping organizations comply with regulatory standards and protect user trust. It highlights the importance of context-aware strategies, such as considering user identity, device posture, location, and application risk when designing access controls, and encourages continuous vigilance in updating components and monitoring for emerging threats.

Ultimately, the OWASP Top 10 is more than a list of vulnerabilities—it is a **framework for cultivating a security-aware development culture**. By internalizing these principles, organizations can move from reactive security measures to proactive defense, creating resilient applications that withstand evolving cyber threats.

Stage 2: A **Nessus scan** provides a comprehensive assessment of an organization's IT environment, identifying vulnerabilities, misconfigurations, and potential security risks across systems, networks, and applications. The scan evaluates devices for missing patches, outdated software, weak configurations, and known vulnerabilities, assigning severity levels to help prioritize remediation efforts. By analyzing the results, organizations gain **visibility into their attack surface**, understand which assets are most at risk, and can make informed decisions about patching, hardening, or isolating vulnerable systems.

The conclusion from a Nessus scan should emphasize the **overall security posture**, highlighting trends such as recurring vulnerabilities, high-severity exposures, or areas of

non-compliance with organizational or regulatory security standards. It should also recommend actionable steps, such as immediate remediation of critical vulnerabilities, continuous patch management, and configuration improvements, along with the implementation of ongoing vulnerability scanning to detect new threats.

Ultimately, Nessus scans are a proactive tool for **risk management**, enabling organizations to reduce the likelihood of exploitation, maintain system integrity, and ensure compliance. Regular scanning, combined with structured remediation, strengthens cybersecurity defenses, provides measurable security improvements over time, and supports a culture of continuous vigilance against emerging threats.

Stage 3: Designing and implementing context-aware access controls represents a modern and proactive approach to securing applications and sensitive data. Unlike traditional access models that rely solely on static credentials or role-based permissions, context-aware access evaluates multiple factors in real time to determine whether a user should be granted access. Central to this approach is user identity, which ensures that only authenticated and authorized individuals can access systems or data. However, identity alone is insufficient in today's complex IT environments, where compromised credentials or insider threats can bypass traditional security measures.

Device posture adds another layer of assurance by assessing the security state of the device requesting access. This includes checking for updated operating systems, active endpoint protection, device compliance with corporate policies, and the absence of malware. By verifying device integrity, organizations can prevent insecure or unmanaged devices from becoming a gateway for attacks.

Location plays a critical role by identifying unusual or high-risk access attempts. Requests originating from untrusted geographic regions, public networks, or anomalous locations can trigger additional authentication measures or be temporarily blocked, mitigating the risk of unauthorized access. Application risk further refines access decisions by evaluating the sensitivity of the resource or action being requested. High-risk applications, such as financial systems or administrative portals, may require multi-factor authentication or stricter access controls, whereas low-risk applications can be accessed more freely.

By combining these factors, context-aware access controls enable organizations to implement adaptive, risk-based policies that balance security with usability. They reduce the likelihood of unauthorized access, data breaches, and insider threats while allowing legitimate users to access resources efficiently. In increasingly cloud-based, mobile, and hybrid IT environments, this approach provides a forward-looking, resilient

security framework that adapts to emerging threats and ensures continuous protection of critical assets.

Future Scope:

Stage 1: The OWASP Top 10 has long served as a foundational framework for identifying and mitigating the most critical web application security risks. As technology continues to evolve, its future scope is increasingly focused on emerging threats, complex architectures, and advanced development paradigms. One significant area is the growth of cloud-native applications, microservices, and API-driven systems, which introduce new attack surfaces and require updated security controls. OWASP is expected to expand guidance around API security, serverless functions, containerized environments, and supply chain risks, reflecting the shift from monolithic applications to distributed systems.

Another key future direction is the integration of context-aware, risk-based security approaches, including identity-driven access controls, device posture verification, and adaptive authentication. As AI, machine learning, and automation become more prevalent in software development and operations, the Top 10 may incorporate threat modeling and vulnerability prioritization frameworks that leverage real-time analytics to identify high-risk components proactively.

OWASP is also likely to emphasize privacy, regulatory compliance, and secure DevOps practices (DevSecOps), bridging the gap between development speed and security assurance. Continuous monitoring, automated scanning, and early security integration into the software lifecycle are expected to be highlighted.

In essence, the future scope of the OWASP Top 10 is not only to remain a baseline for traditional web security but also to adapt to emerging technologies, evolving threat landscapes, and proactive risk management strategies, ensuring organizations can build resilient, secure, and compliant applications in increasingly complex digital ecosystems.

Stage 2: **Nessus**, as one of the most widely used vulnerability assessment tools, has become a critical component of proactive cybersecurity strategies. Its future scope is closely tied to the evolving threat landscape, increasing complexity of IT environments, and the growing emphasis on automation and continuous monitoring. Traditional vulnerability scanning will continue to expand into **cloud environments, hybrid networks, containers, and serverless architectures**, where assets are dynamic and ephemeral. Nessus will need to enhance its ability to detect vulnerabilities across these

rapidly changing infrastructures, including **cloud workloads, APIs, microservices, and IoT devices**.

Another key area of development is **integration with automated security and DevSecOps workflows**. By embedding Nessus scans into CI/CD pipelines, organizations can identify and remediate vulnerabilities earlier in the software development lifecycle, reducing the window of exposure. Advanced features such as **risk prioritization, predictive analytics, and AI-driven vulnerability assessment** are likely to become standard, enabling security teams to focus on high-impact threats rather than volume-based alerts.

Additionally, regulatory compliance and audit readiness will drive Nessus to provide **deeper reporting, real-time dashboards, and actionable remediation guidance**. Future enhancements may also include **integration with threat intelligence feeds** to detect zero-day exploits and contextualize vulnerabilities based on active threat landscapes.

In summary, the future of Nessus scanning will focus on **automation, intelligence-driven assessments, cloud and hybrid environment coverage, and seamless DevSecOps integration**, positioning it as a critical tool for organizations seeking continuous, adaptive, and proactive cybersecurity defenses in an increasingly complex IT ecosystem.

Stage 3: The future of context-aware access control is closely aligned with the growing complexity of IT environments, cloud adoption, mobile and remote work, and the rise of sophisticated cyber threats. Traditional static access control models are no longer sufficient, as they cannot dynamically respond to evolving risk factors or user behavior. The next generation of access control systems will increasingly leverage real-time analytics, artificial intelligence, and machine learning to continuously evaluate context and adapt permissions automatically.

User identity will evolve beyond simple authentication to include behavioral biometrics, risk-based profiling, and federated identity management across multi-cloud and hybrid environments. Device posture assessments will become more sophisticated, encompassing IoT devices, mobile endpoints, and unmanaged hardware, with automated remediation for non-compliant or compromised devices. Location awareness will expand to include network context, geofencing, and anomaly detection to identify unusual access patterns. Application risk evaluation will incorporate dynamic threat intelligence, transaction sensitivity, and regulatory requirements to prioritize access restrictions in real time.

The future also emphasizes integration with Zero Trust and DevSecOps frameworks, allowing organizations to enforce granular, adaptive, and continuous access policies across all digital assets. Automation and AI-driven decision-making will reduce administrative overhead while improving security effectiveness. Ultimately, context-aware access control will evolve into a predictive and intelligent system, providing seamless, secure access while proactively mitigating risks and insider threats in increasingly complex, cloud-native, and distributed IT ecosystems.

Topics Explored: OWASP TOP 10, Scanning, Vulnerability, Awareness, Identity, User Identity, Device Posture, Location, Application Risk, Context-Aware Access Control Design, Implementation Considerations.

Tools Explored: Zscaler, Nessus, OWSAP, Hackthissite